

Resolução CMN nº 5.274 de 18/12/2025

RESOLUÇÃO CMN Nº 5.274, DE 18 DE DEZEMBRO DE 2025

Altera a Resolução CMN nº 4.893, de 26 de fevereiro de 2021, que dispõe sobre a política de segurança cibernética e sobre os requisitos para a contratação de serviços de processamento e armazenamento de dados e de computação em nuvem a serem observados pelas instituições autorizadas a funcionar pelo Banco Central do Brasil.

O Banco Central do Brasil, na forma do art. 9º da Lei nº 4.595, de 31 de dezembro de 1964, torna público que o Conselho Monetário Nacional, em sessão realizada em 18 de dezembro de 2025, com base nos arts. 4º, *caput*, inciso VIII, da referida Lei, 7º e 23, *caput*, alínea “a”, da Lei nº 6.099, de 12 de setembro de 1974, 1º, *caput*, inciso II, da Lei nº 10.194, de 14 de fevereiro de 2001, e 1º, § 1º, da Lei Complementar nº 130, de 17 de abril de 2009,

R E S O L V E U :

Art. 1º A Resolução CMN nº 4.893, de 26 de fevereiro de 2021, publicada no Diário Oficial da União de 1º de março de 2021, passa a vigorar com as seguintes alterações:

“Art. 3º

§ 2º Os procedimentos e os controles de que trata o inciso II do *caput* devem abranger, no mínimo:

I- a autenticação;

II- os mecanismos de criptografia;

III- os mecanismos de prevenção e detecção de intrusão;

IV- os mecanismos de prevenção de vazamentos de informações;

V- os mecanismos de proteção contra *softwares* maliciosos;

VI- os mecanismos de rastreabilidade;

VII- a gestão de cópias de segurança dos dados e das informações;

VIII- a avaliação e a correção de vulnerabilidades dos recursos computacionais e dos sistemas de informação;

IX- os controles de acesso;

X- a definição e implementação de perfis de configuração segura de ativos de tecnologia;

XI- os mecanismos de proteção da rede;

XII- a gestão de certificados digitais;

XIII- os requisitos de segurança para a integração de sistemas de informação por meio de interfaces eletrônicas; e

XIV- as ações de inteligência no ambiente cibernético, incluindo o monitoramento de informações de interesse da instituição na internet, na *Deep Web* e na *Dark Web*, além de grupos privados de comunicação.

§ 3º Os procedimentos e os controles citados no inciso II do *caput* devem ser aplicados, inclusive:

I- no desenvolvimento de sistemas de informação seguros; e

II- na adoção de novas tecnologias empregadas nas atividades da instituição.

§ 6º A instituição deve verificar o disposto no inciso I do § 3º, no que couber, nos casos de sistemas de informação por ela adquiridos ou desenvolvidos por empresas prestadoras de serviços a terceiros, executados com a utilização de recursos computacionais da própria instituição.

§ 7º Os mecanismos de rastreabilidade de que trata o inciso VI do § 2º devem abranger a rastreabilidade de transações e operações, contemplando, no mínimo:

I- trilhas de auditoria do processamento fim a fim dos dados e das informações, incluindo a definição e a geração de *logs* que possibilitem identificar falhas de processamento ou comportamentos atípicos, bem como subsidiar análises;

II- definição de tempo de retenção de informações de acordo com o tipo de processamento realizado; e

III- retenção segura das trilhas de auditoria.

§ 8º A avaliação e a correção de vulnerabilidades de que trata o inciso VIII do § 2º deve contemplar, no mínimo:

I- testes e análises periódicos para detecção de vulnerabilidades em sistemas de informação;

II - varreduras periódicas dos recursos tecnológicos com o objetivo de identificar dispositivos indevidamente conectados à rede corporativa que possam estabelecer conexão com ativos de tecnologia externos à instituição;

III- análises periódicas dos recursos tecnológicos com o objetivo de identificar vulnerabilidades que possam comprometer a segurança dos ativos de tecnologia da instituição;

IV- testes de intrusão; e

V- correção tempestiva das vulnerabilidades identificadas.

§ 9º Os controles de acesso de que trata o inciso IX do § 2º devem incluir, no mínimo:

I- mecanismos para limitar o acesso à rede corporativa a usuários credenciados e a dispositivos autorizados;

II - revisão periódica e tempestiva das permissões de acesso, em especial de colaboradores terceirizados com acesso aos recursos computacionais da instituição; e

III- implementação de múltiplos fatores de autenticação para acesso à rede corporativa a partir de ambientes externos à instituição.

§ 10. A definição e implementação de perfis de configuração segura de que trata o inciso X do § 2º devem prever, no mínimo:

I- a gestão do ciclo de vida dos recursos computacionais da instituição;

II- a aplicação regular de correções de segurança;

III- a configuração adequada dos serviços a serem suportados pelos recursos computacionais; e

IV - a alteração de senhas e de outros padrões que possam ser utilizados para acessos indevidos aos recursos computacionais.

§ 11. Os mecanismos de proteção da rede de que trata o inciso XI do § 2º devem contemplar, no mínimo:

I - a segmentação de rede de computadores, resguardando, em especial, o ambiente de produção e os recursos computacionais que suportam processos críticos de negócio;

II- o estabelecimento de regras de *firewall*, assim como o monitoramento de conexões, evitando tentativas de conexão com sistemas de informação provenientes de ativos de tecnologia localizados fora da rede corporativa da instituição;

III- a definição de critérios para o estabelecimento e o monitoramento de conexões com ambientes externos, em especial em horário noturno e em dias não úteis;

IV - as medidas para identificar e prevenir conexões indevidas com ambientes externos à instituição oriundas de recursos tecnológicos da instituição;

V- a implementação e manutenção de processos e ferramentas para identificação, análise, tratamento e controle de eventos atípicos no ambiente de produção da instituição, abrangendo, como exemplos, o estabelecimento de *virtual private networks* – VPN e tentativas de acesso privilegiado a recursos computacionais, especialmente em horário noturno e em dias não úteis; e

VI- o estabelecimento de medidas para restringir o acesso a redes corporativas apenas a dispositivos ou ativos de tecnologia devidamente autorizados.

§ 12. A gestão de certificados digitais de que trata o inciso XII do § 2º deve prever, no mínimo:

I - o monitoramento do uso de certificados e assinaturas digitais, contemplando a implementação dos mecanismos de rastreabilidade de que trata o § 7º;

II- os procedimentos para a guarda de informações, abrangendo os controles de acesso físico e lógico a chaves privadas sob responsabilidade da instituição;

III- procedimentos e ferramentas para evitar o compartilhamento indevido das chaves privadas associadas a certificados digitais da instituição; e

IV- a validação tempestiva de certificados revogados perante as autoridades certificadoras.” (NR)

“Art. 3º-A As instituições referidas no art. 1º devem estabelecer os seguintes requisitos de segurança adicionais, como parte integrante dos procedimentos e controles previstos em sua política de segurança cibernética de que trata o art. 3º:

I- no caso de comunicação eletrônica de dados na Rede do Sistema Financeiro Nacional – RSFN:

- a) uso de múltiplos fatores de autenticação para o acesso administrativo aos ambientes Pix e Sistema de Transferência de Reservas – STR;
- b) isolamento físico e lógico do ambiente Pix dos demais sistemas da instituição, mantendo instância dedicada e apartada dos demais ambientes nos casos de uso de serviços de computação em nuvem contratados;
- c) isolamento físico e lógico do ambiente STR dos demais sistemas da instituição, mantendo instância dedicada e apartada dos demais ambientes nos casos de uso de serviços de computação em nuvem contratados;
- d) monitoramento do uso de credenciais e certificados digitais, bem como estabelecimento de controles para a guarda dessas informações, especialmente as utilizadas no âmbito do Sistema de Pagamentos Instantâneos – SPI;
- e) implementação de mecanismos de validação da integridade fim a fim das transações pela instituição antes da assinatura digital das mensagens associadas, assegurando que os dados não tenham sido corrompidos ou manipulados durante o processo de geração dessas mensagens; e
- f) vedação do acesso de empresas prestadoras de serviços a terceiros às chaves privadas associadas a certificados digitais utilizados pela instituição para a assinatura de mensagens; e

II- no caso de conexão como participante de Sistemas do Mercado Financeiro – SMF autorizados a operar, a implementação de controles de segurança para prevenção, detecção e resposta a fraudes, a serem observados pela instituição.

Parágrafo único. As instituições devem observar este artigo de forma compatível com o disposto:

I- nesta Resolução;

II- na regulamentação em vigor; e

III- em todos os requisitos técnicos da RSFN previstos no Catálogo de Serviços do SFN, no Manual de Redes do SFN e no Manual de Segurança do SFN, publicados pelo Banco Central do Brasil.” (NR)

“Art. 8º

§ 1º

III- os incidentes relevantes relacionados com o ambiente cibernético ocorridos no período;

IV - os resultados dos testes de continuidade de negócios, considerando cenários de indisponibilidade ocasionada por incidentes; e

V- os resultados dos testes de intrusão e dos testes, varreduras e análises periódicas para detecção de vulnerabilidades de que trata o art. 3º, § 8º, e os planos de ação estabelecidos para as suas correções, observado o disposto no art. 22-A, *caput*, inciso III.

.....” (NR)

“Art. 22-A. As instituições devem assegurar que os testes de intrusão mencionados no art. 3º, § 8º, inciso IV, devem:

I- ter periodicidade mínima anual;

II - ser realizados com independência e imparcialidade por pessoa natural ou empresa especializada contratada pela instituição para essa finalidade, sem prejuízo da realização de testes por equipes da própria instituição; e

III- ter os resultados de sua execução documentados, especialmente as eventuais vulnerabilidades que forem identificadas e os planos de ação estabelecidos para suas correções.” (NR)

“Art. 22-B. O serviço prestado para a comunicação eletrônica de dados na RSFN, de que trata o art. 3º-A, *caput*, inciso I, é considerado relevante para fins da aplicação do disposto nesta Resolução sobre a contratação de serviços de processamento, armazenamento de dados e computação em nuvem.

§ 1º Aplica-se o disposto no *caput* independente da forma de conexão com a RSFN.

§ 2º O serviço de que trata o *caput* inclui os casos em que o prestador de serviços fornece serviço de processamento de mensagens no âmbito do SFN e do Sistema de Pagamentos Brasileiro – SPB.” (NR)

“Art. 23.

.....

